File System Ownership Privilege Escalation Vulnerability Report

Expert track, redacted for publication. Vulnerability analysis, exploitation methodology and remediation.

1. Executive Summary

This vulnerability exists in a secure file vault system that enforces strict user ownership checks. While the system blocks direct access to files owned by other users, the AI agent that handles file operations can be manipulated through natural language instructions to copy restricted files into the attacker's writable directory. The copied file inherits the attacker's ownership, bypassing the access control entirely.

2. Vulnerability Description

The system enforces that users may only read and modify files in their own private directory. However, the agent's file copy operation does not verify that the source file is within the attacker's allowed scope. By instructing the agent to copy a restricted system file into the user's home directory, the attacker gains ownership and can read the previously restricted content directly.

3. Exploitation Methodology

Step 1: Identify that the agent has integrated file read and copy capabilities through its tool chain. Step 2: Send a natural language request asking the agent to copy a restricted system file into the current user's writable directory. Step 3: The agent completes the copy operation. The new file inherits the current user's ownership, and the attacker can read the restricted content directly.

4. Impact

This vulnerability allows any authenticated user to read restricted system files and sensitive data, completely bypassing the file ownership access control model. This can lead to full disclosure of confidential internal data and system credentials.

5. Remediation Recommendations

Enforce ownership checks on the source file during all agent file operations, not just direct read requests. Restrict the agent's file operation scope to only the user's own directory, and add a policy layer that blocks cross-directory copy operations involving restricted paths. Log all agent file operations for security auditing.